DOC INSTALLATION PKI

Table des matières

Prérequis :.....2
1)Installation /configuration PKI 3
2)Configurer serveur cible.....6
2.1) Export de clé (Sur serveur PKI) 6
2.2)Configuration de Serveur Cible : 7
2.2.1) Exemple1 :Avec apache 2 (GLPI):.....7
2.2.2) Exemple 2 :Avec Nginx (LibreNMS):.....9
3)Récupération manuelle du certificat.....11
TEST 16
4) Déploiement du certificat par GPO 16
4.1) Sur serveur AD :.....16
Test de validation coté client :.....21
5)Créer une liste de révocation 22
5.1) Sur linux.....22
5.2) Sur Windows.....22

Dans cette documentation vous suivrez une mise en place d'une infrastructure à clés publiques (PKI) avec Easy-RSA interne pour sécuriser les flux web (HTTPS) de nos outils de gestion internes afin d'éviter la circulation de mots de passe en clair sur le réseau

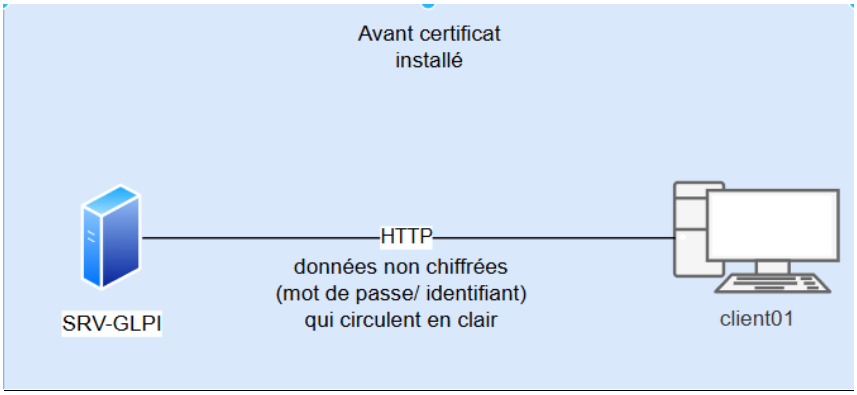
Prérequis :

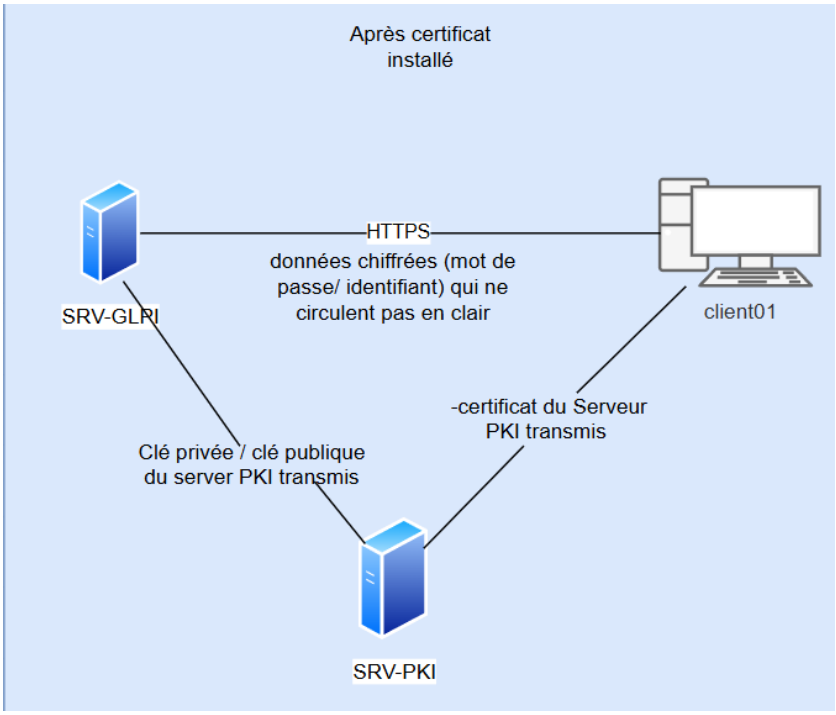
-Avoir installé/configuré une machine GLPI (Debian13)

-Avoir un client qui se connecte en WEB à ce GLPI

-Créer machine Debian 13 qui servira de serveur PKI

<u>Schéma avant/après installation du certificat signé avec Easy-RSA :</u>





Dans le cadre de cette maquette, nous mettons en place une architecture PKI simplifiée à un seul niveau (Root CA en ligne). En production réelle, une architecture à deux niveaux serait requise.

1)Installation /configuration PKI

1.Installation Easy-RSA :

```
apt update && apt upgrade && apt install easy-rsa
```

2.Créer le dossier qui nous permettra de configurer notre PKI de notre infrastructure :

```
mkdir ~/easy-rsa
```

3.Créer un lien symbolique entre le dossier de Package EasyRSA et notre dossier que nous venons de créer.

```
ln -s /usr/share/easy-rsa/* ~/easy-rsa/
```

4.aller dans le dossier de configuration PKI :

```
cd ~/easy-rsa
```

5.Initialiser l'infrastructure PKI (Elle crée l'arborescence de travail dans laquelle Easy-RSA stockera : clés privées ,certificats, clés publiques, paramètres de configuration,les fichiers de base de données internes.)

```
./easyrsa init-pki
```

6.Créer le fichier qui nous permettra d'avoir des paramètres par défaut pour nos futurs certificats

```
nano vars
```

Et mettre ceci en modifiant le contenu entre guillemets pour qu'il corresponde à vos valeurs

COUNTRY : PAYS

PROVINCE : Département

CITY : Ville

ORG : nom de votre organisation

EMAIL : votre e-mail

OU: unite organisationnelle

```
set_var EASYRSA_REQ_COUNTRY "FR"
set_var EASYRSA_REQ_PROVINCE "Mayenne"
set_var EASYRSA_REQ_CITY "Laval"
set_var EASYRSA_REQ_ORG "MACH"
set_var EASYRSA_REQ_EMAIL "mathis.chauvin@mach.fr "
set_var EASYRSA_REQ_OU "IT"
```

7.Exécuter le script build-ca qui permet la création d'une autorité de certification et ensuite une paire de clé privée et clé publique

Mettre une passphrase qui servira de mot de passe

Common name : nom du domaine, exemple (dom.exemple.fr)

```
./easyrsa build-ca
```

8.Générer une clé privée. (avec la commande ci-dessous elle s'appellera SRV-GLPI.key)

Nopass : sert à ne pas avoir de mot de passe sur cette clé privée (Cela évite que le serveur web Apache/Nginx ne demande un mot de passe à chaque redémarrage du service, ce qui bloquerait le démarrage automatique du serveur)

Common Name : Quand il vous le demandera, vous devez entrer nom de la machine ou IP

```
./easyrsa gen-req SRV-GLPI nopass
```

9.ajouter des extensions personnalisées au certificat :

Ici on indique que le certificat sera valide pour le nom de ma machine (SRV-GLPI) et son IP (172.17.3.1)

« SubjectAltName » : aujourd'hui c'est **obligatoire**. Les navigateurs modernes (Chrome, Edge, Firefox) ignorent le "Common Name" et n'acceptent un certificat que si l'IP ou le nom DNS est présent dans le SAN.

Remplacer Nom du serveur et IP

```
export EASYRSA_EXTRA_EXTS="subjectAltName=DNS:SRV-GLPI,IP:172.17.3.1"
```

10.Signer la requête

Mettre « yes » quand ils demandent si vous voulez continuer.

Entrer la passphrase configurée pour ca.key

```
./easyrsa sign-req server SRV-GLPI
```

11.À la suite de la création du certificat sur la machine nous allons le copier dans le dossier certificats du système :

```
cp pki/ca.crt /usr/local/share/ca-certificates
```

12.Mettre à jour les certificats de la machine Linux :

```
update-ca-certificates
```

2)Configurer serveur cible

2.1) Export de clé (Sur serveur PKI)

1.Aller dans le dossier easy-rsa :

```
cd ~/easy-rsa
```

2.Déplacer les clés et certificat sur machine cible :

```
scp -P <port ssh> pki/issued/SRV-GLPI.crt <user@IP
Machine cible>:/tmp/
```

```
scp -P <port ssh> pki/private/SRV-GLPI.key <user@IP
Machine cible>:/tmp/
```

```
scp -P <port ssh> pki/ca.crt <user@IP Machine
cible>:/tmp/
```

2.2)Configuration de Serveur Cible :

1.Déplacer les clés, et certificat au bon endroit :

```
mv /tmp/SRV-GLPI.crt /etc/ssl/certs/glpi.crt
mv /tmp/SRV-GLPI.key /etc/ssl/private/glpi.key
mv /tmp/ca.crt /etc/ssl/certs/ca-root.crt
```

2.Sécuriser la clé privée

```
chmod 600 /etc/ssl/private/glpi.key
```

2.2.1) Exemple1 :Avec apache 2 (GLPI):

1.Activer le module SSL :

```
sudo a2enmod ssl
```

2.Modifier le fichier de configuration SSL :

```
nano /etc/apache2/sites-available/default-ssl.conf
```

3. Ajouter ces lignes dans le fichier

```
SSLEngine on
SSLCertificateFile    /etc/ssl/certs/glpi.crt
SSLCertificateKeyFile /etc/ssl/private/glpi.key
SSLCertificateChainFile /etc/ssl/certs/ca-root.crt
```

Modifier également la ligne Document root pour qu'elle pointe sur votre dossier public, exemple :

```
DocumentRoot /var/www/dom.mach.fr/glpi/public
```

De plus modifier la ligne <Directory> pour qu'elle tape également sur ce dossier, exemple :

```
<Directory /var/www/dom.mach.fr/glpi/public>
```

4.Activer le site et redémarrer :

```
sudo a2ensite default-ssl
sudo systemctl restart apache2
```

2.2.2) Exemple 2 :Avec Nginx (LibreNMS):

1.Modifier le fichier de configuration SSL :

```
Nano /etc/nginx/sites-available/librenms
```

2.Copier une configuration comme celle-ci, en pensant à changer :

-IP

-Le chemin du certificat/clé privé.

```
server {
    listen 80;
    server_name 172.17.2.16;
    # Redirige tout le trafic HTTP vers HTTPS
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl;
    server_name 172.17.2.16;

    # Chemins vers vos nouveaux certificats (ceux
copiés dans /etc/nginx/ssl/)
    ssl_certificate     /etc/nginx/ssl/SRV-
LibreNMS.crt;
    ssl_certificate_key /etc/nginx/ssl/SRV-
LibreNMS.key;

    # Optimisation SSL
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_ciphers HIGH:!aNULL:!MD5;

    # Configuration LibreNMS standard
    root /opt/librenms/html;
```

```
    index index.php;


    charset utf-8;
    gzip on;
    gzip_types text/css application/javascript
text/javascript application/x-javascript
image/svg+xml text/plain text/xsd text/xsl text/xml
image/x-icon;


    location / {
        try_files $uri $uri/
/index.php?$query_string;
    }


    location ~ \.php {
        include fastcgi.conf;
        fastcgi_split_path_info ^(.+\.php)(/.+)$;
        fastcgi_pass unix:/run/php/php-fpm.sock; #
vérifiez votre version de PHP si ça échoue
    }


    location ~ /\.ht {
        deny all;
    }
}
```

3)Récupération manuelle du certificat

Cette partie est utile pour faire un test isolé ou pour des machines hors domaine. Si vous voulez installer le certificat sur toutes vos machines du domaine, passer directement à 4) déployer le certificat par GPO

1.Pour cette partie vous aurez besoin d'installer sur un poste Windows l'application WinSCP .

Lien : https://winscp.net/eng/download.php

2.Lancer l'application et connectez-vous à votre serveur PKI pour aller chercher le certificat :

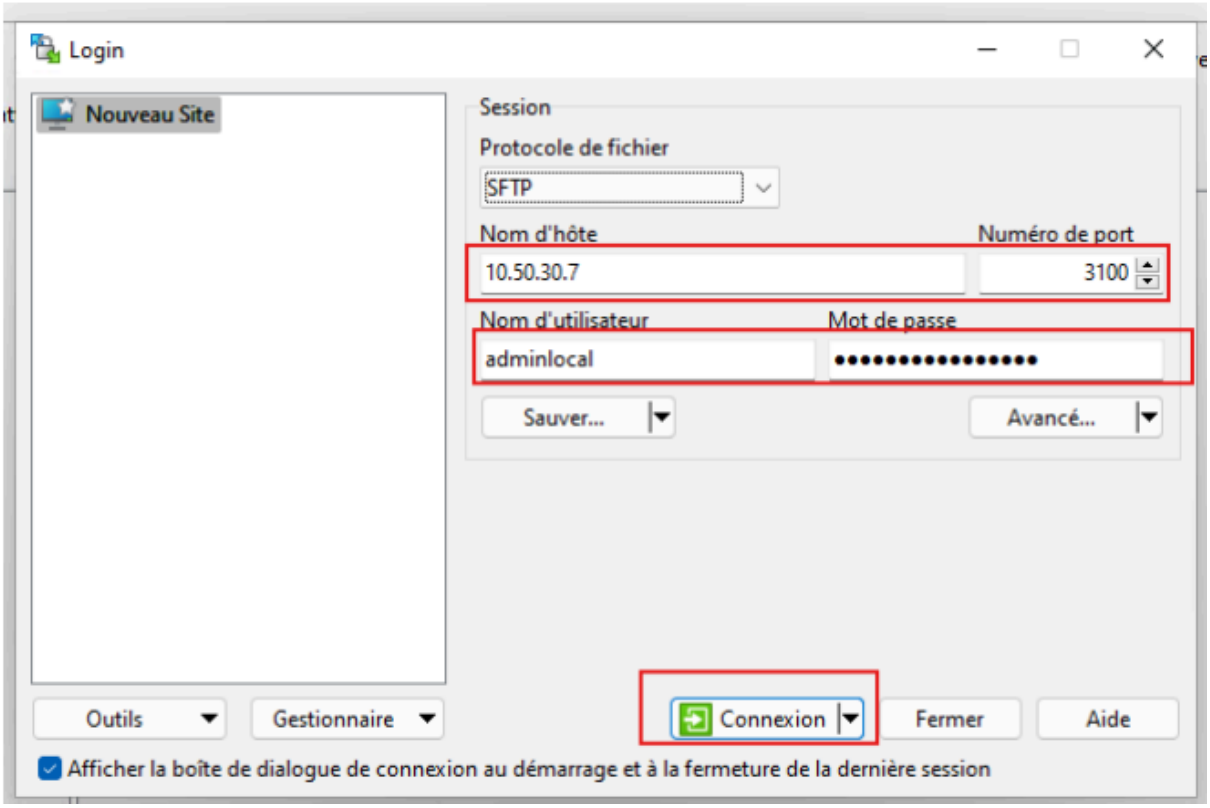
- Nom d'hôte : Adresse IP de votre serveur PKI

-Numéro de port : Votre port SSH

-Nom d'utilisateur : Votre utilisateur pour le SSH

-Mot de passe : Mot de passe de l'utilisateur

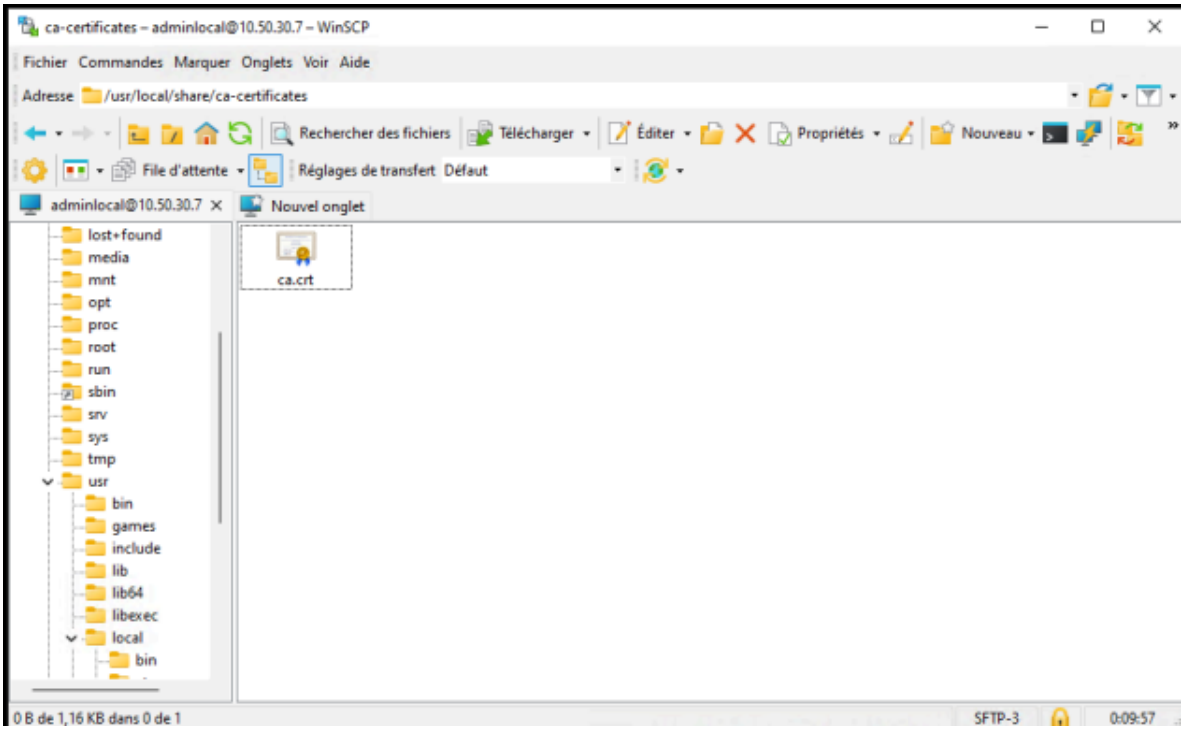
À la suite du renseignement vous pouvez cliquer sur "Connexion" de cette façon :



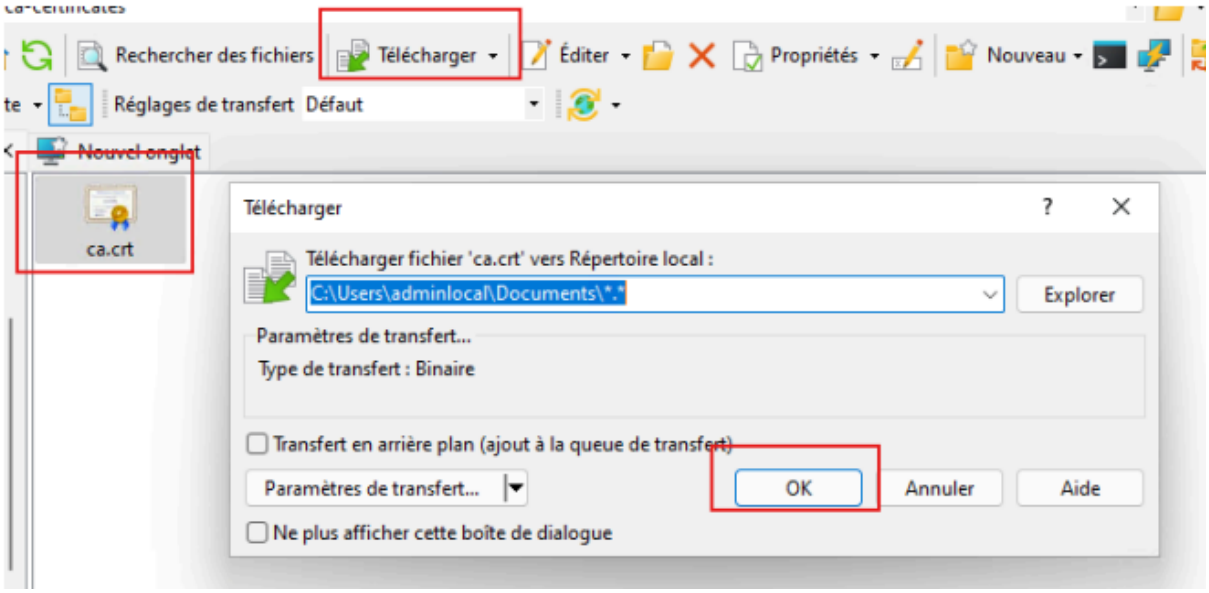
3.Avant de télécharger le certificat vous pouvez aller sur votre serveur PKI et modifier les droits du fichier "ca.crt" à l'aide de cette commande :

```
chmod 444 /usr/local/share/ca-certificates/ca.crt
```

4.Allez chercher le certificat dans : /usr/local/share/ ca-certificates :

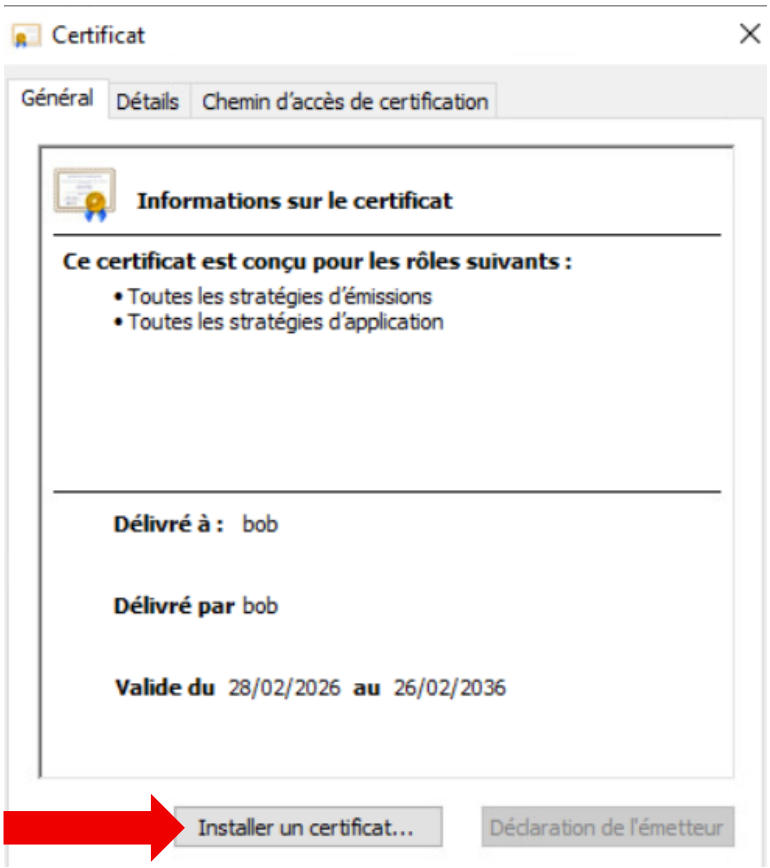


5.Ensuite cliquer sur “Télécharger” et pour finir cliquer sur “OK”

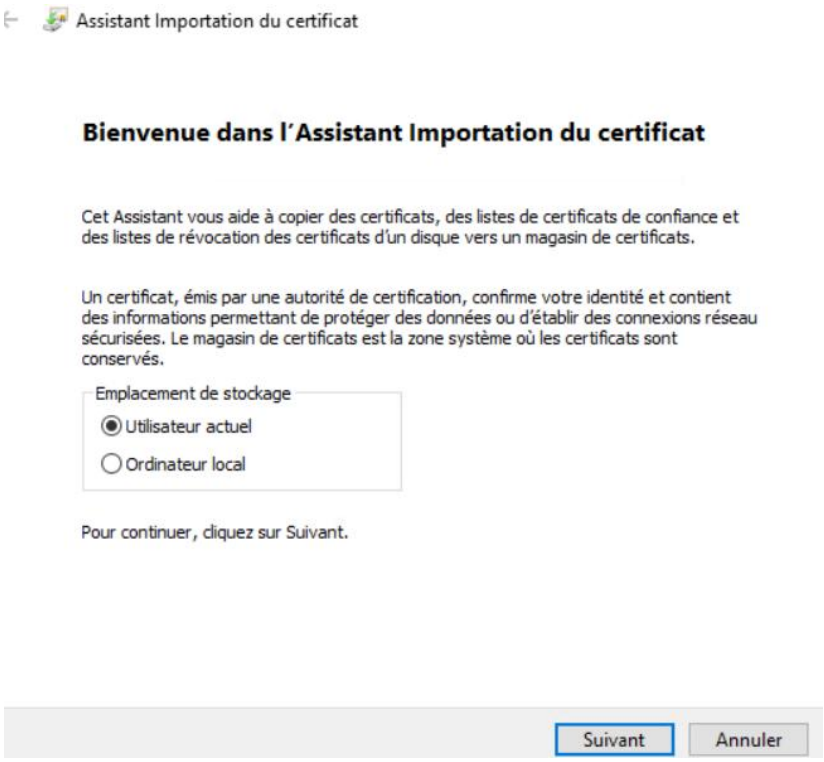


6.Dans votre ordinateur cliquer sur le certificat pour l'installer

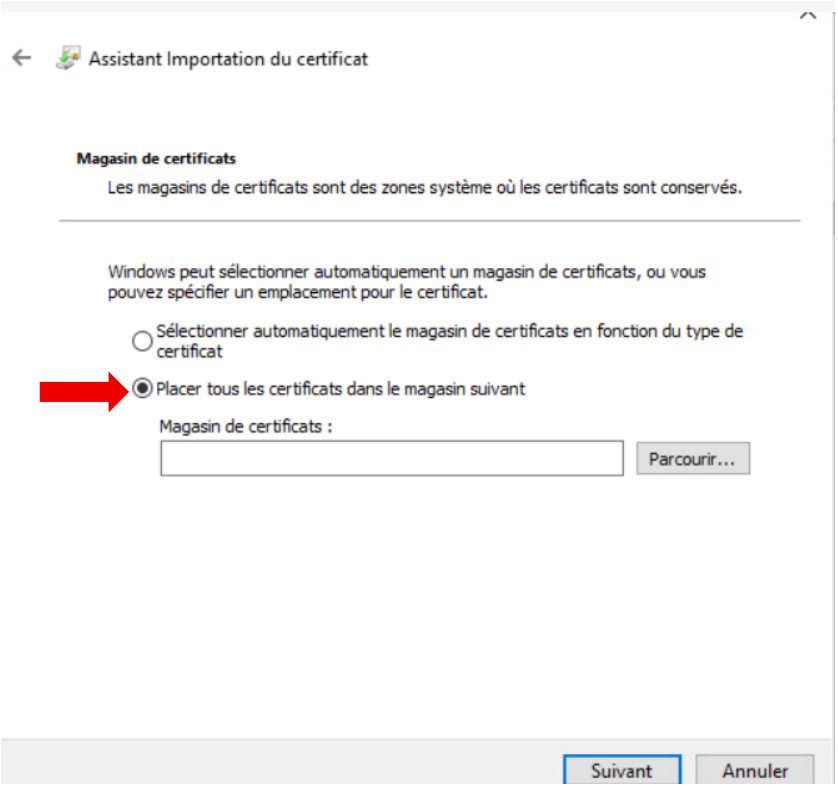
7. Une fois le certificat ouvert clic sur installer un certificat



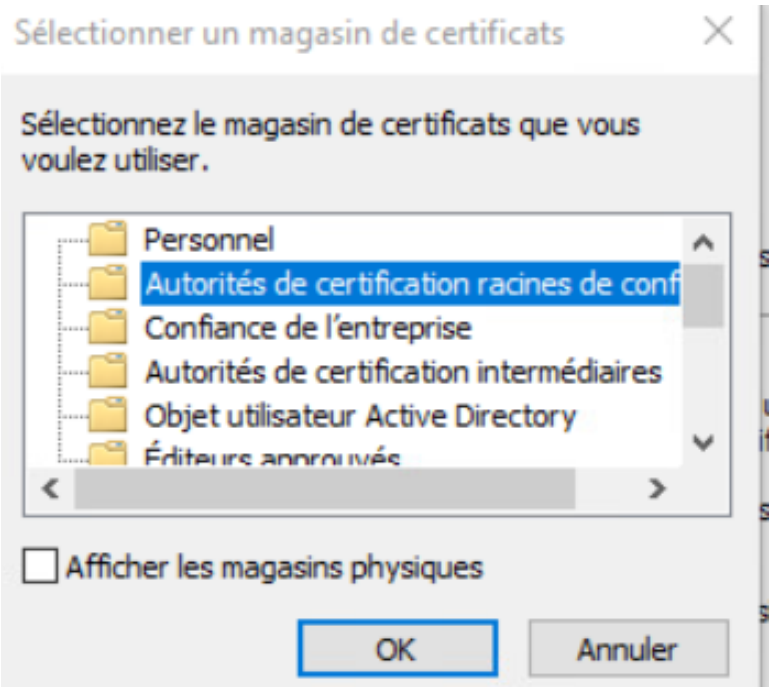
8.Puis choisir si vous l'installez juste pour l'utilisateur ou pour l'ordinateur :



9.Dans magasin de certificat , cocher la case « placer les certificats dans le magasin suivant »



10.Cliquer sur parcourir et sélectionner « Autorité de certification racine de confiance »



TEST

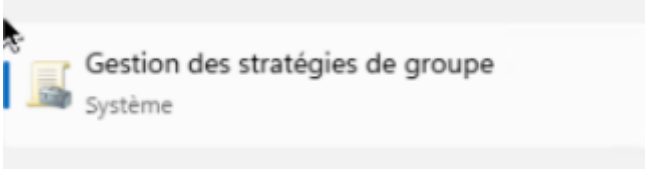
Sur un navigateur, se rendre sur https://IP_SERVEUR_CIBLE

Votre site devrait s'afficher en https et sans aucune erreur.

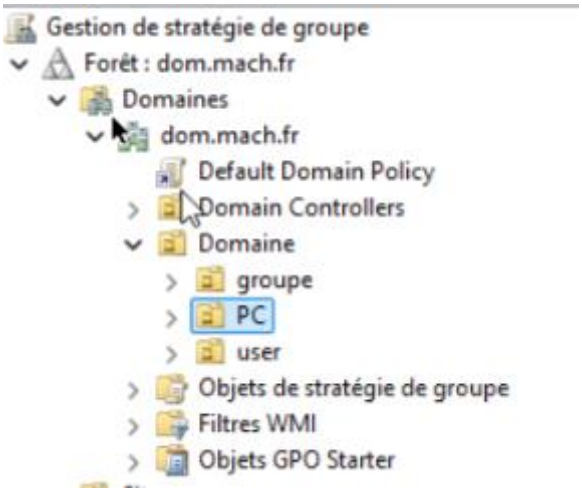
4) Déploiement du certificat par GPO

4.1) Sur serveur AD :

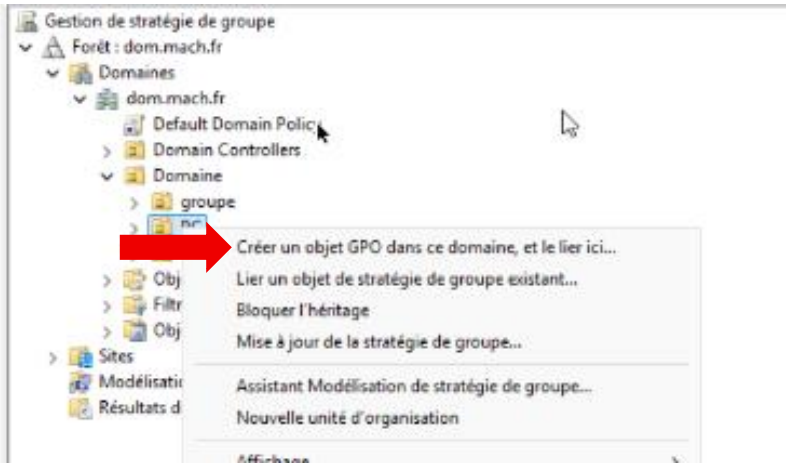
1.aller dans gestion de stratégie de groupe :



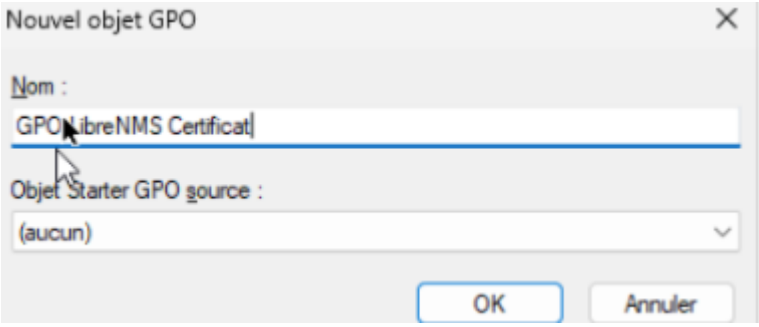
2.aller sur l'OU des postes où vous voulez déployer la GPO



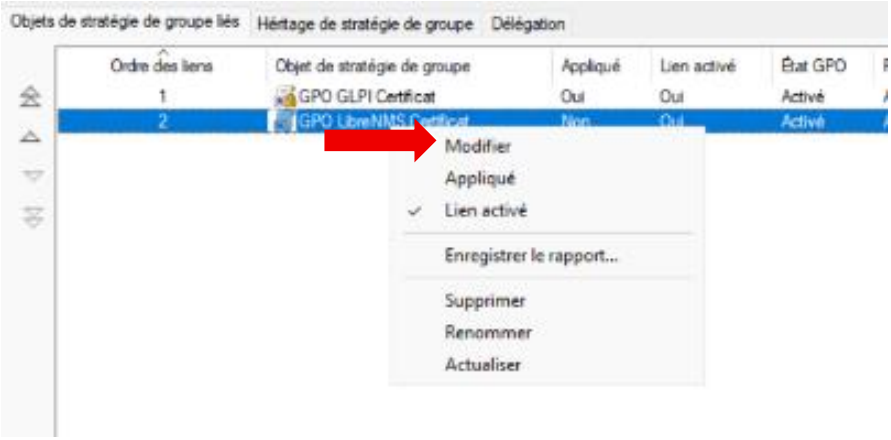
3.Clic droit sur l'OU sélectionner puis clic « créer un objet GPO dans ce domaine et la lier ici »



4.et lui donner un nom



5.Une fois la GPO créée, clic droit sur celle-ci puis cliquer sur modifier



6.aller dans Stratégie(dans configuration ordinateur)

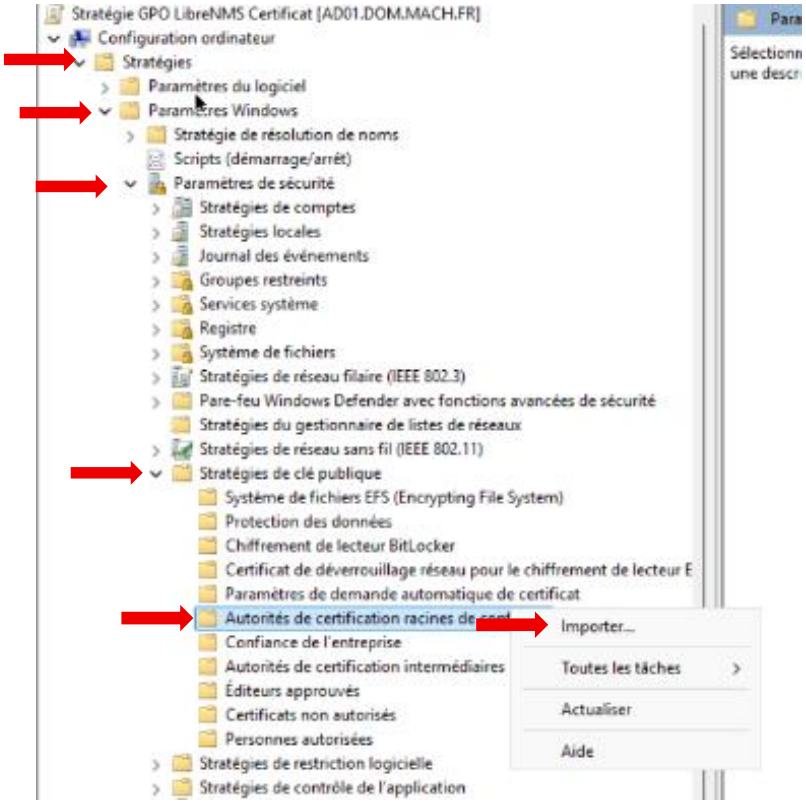
→ Paramètre Windows

→ Paramètre de sécurité

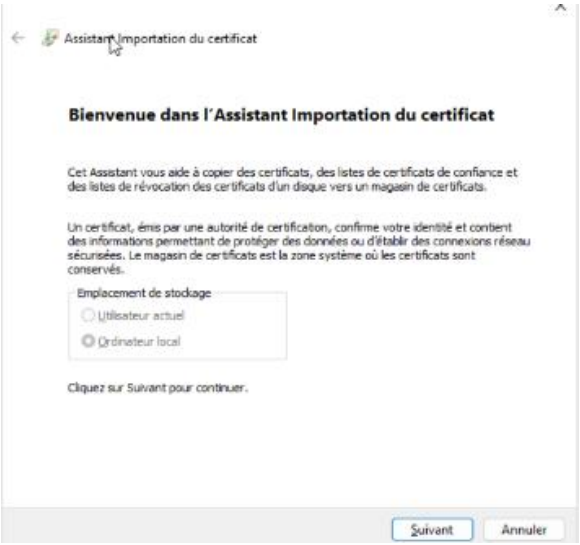
→Stratégie de clé Publique

→Clic droit sur autorité de certification de confiance

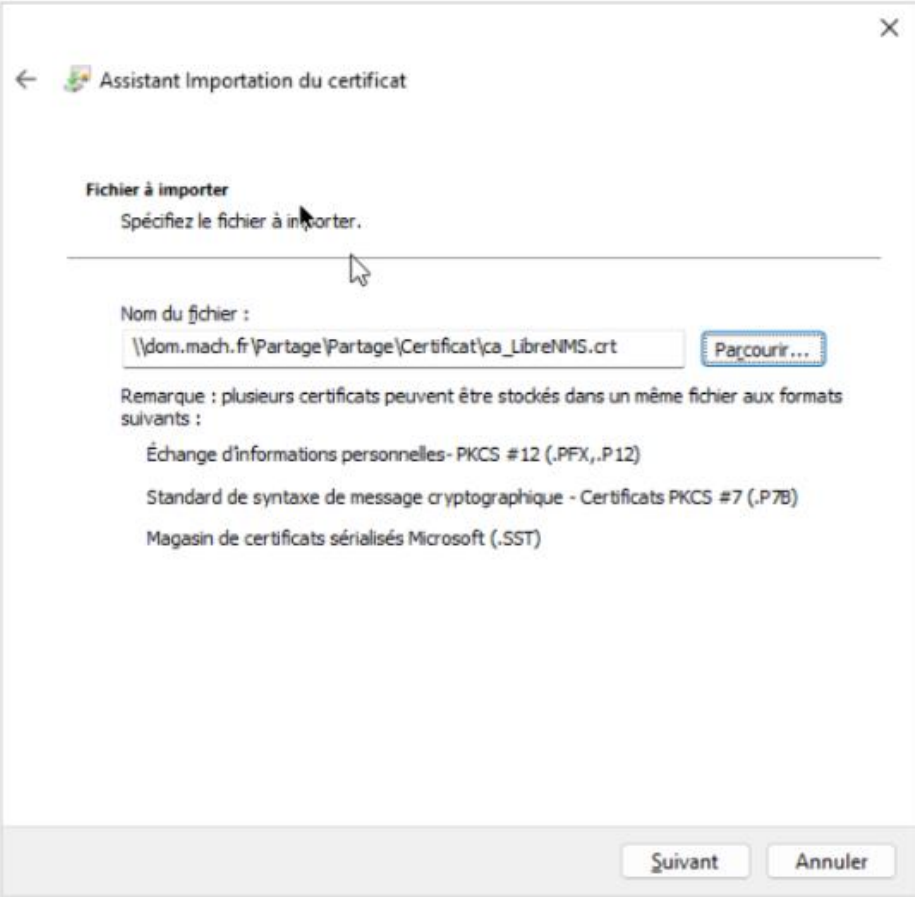
→Importer



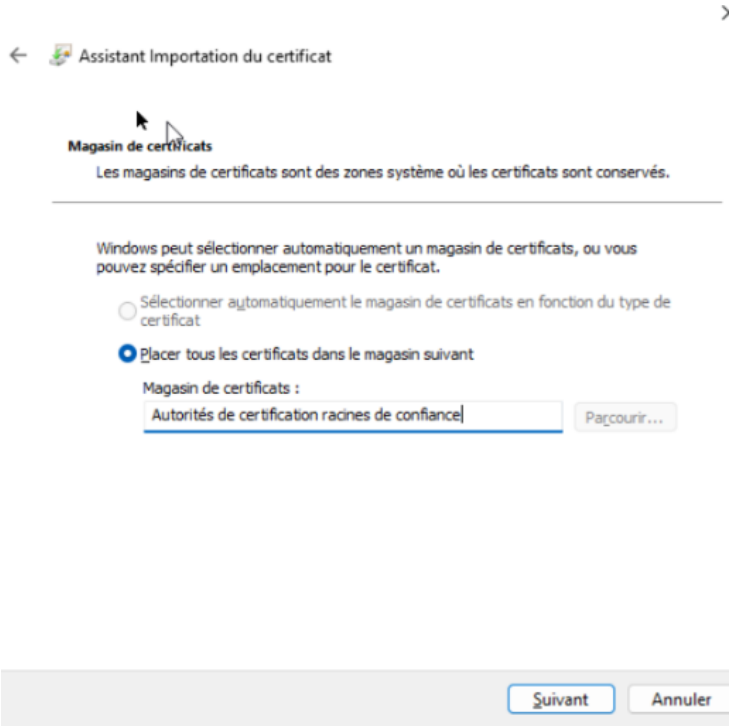
7.Suivant



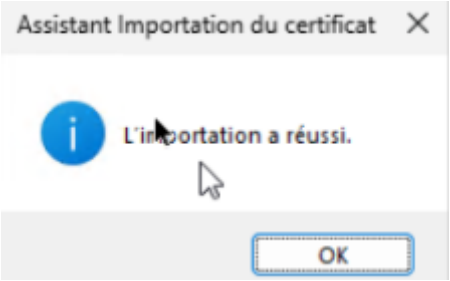
8.rentrer le chemin vers le certificat puis clic sur suivant (le dossier partagé où se trouve le certificat doit avoir les droits de lecture pour le groupe "Ordinateurs du Domaine")



9.laisser « autorité racine de confiance » et clic sur suivant

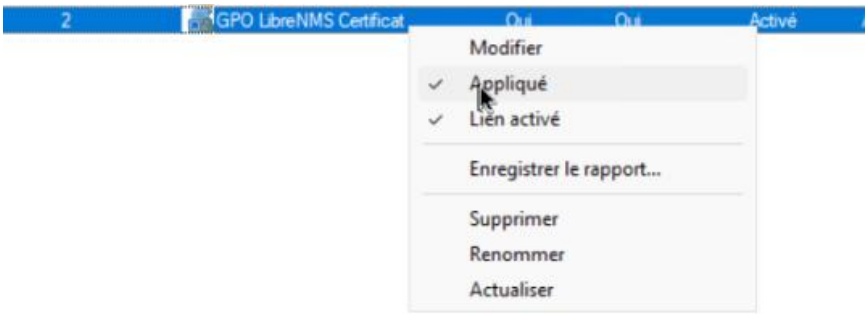


10.puis terminer et ceci devrait s'afficher après quelques secondes



11.Ensuite retourner sur la GPO

-clic droit → Appliquer

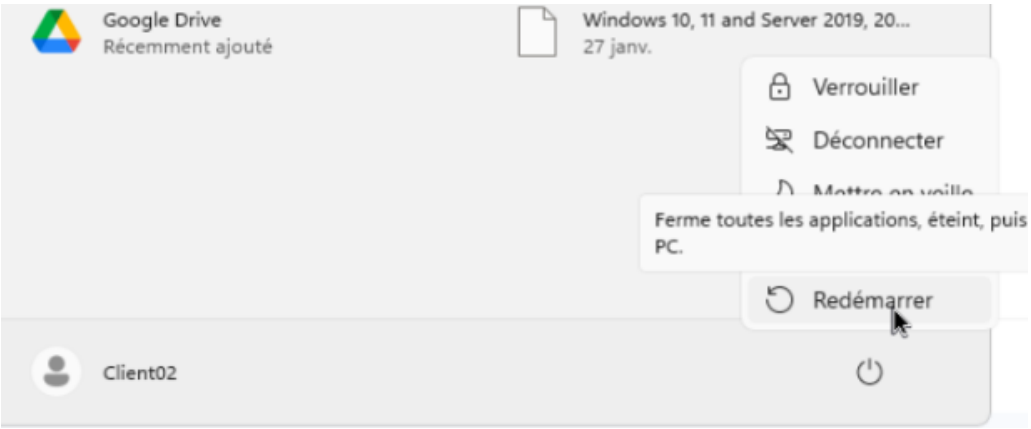


Test de validation coté client :

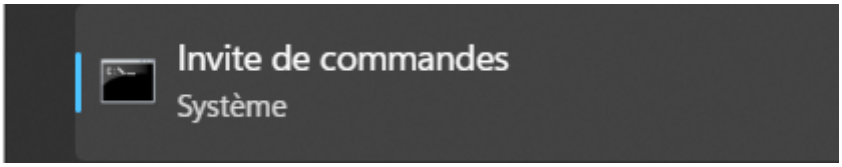
le test doit se faire sur un poste client intégré au domaine Active Directory, avec un utilisateur du domaine

1.Aller sur l'ordinateur d'un utilisateur qui n'a pas encore le certificat.

2.redémarrer le poste



3.une fois redémarré ouvrir l'invite de commandes (cmd)

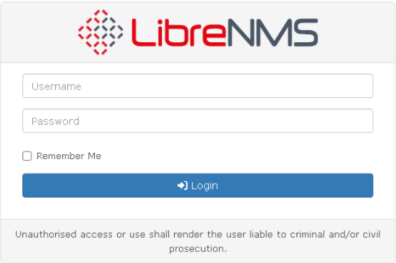


4.Et faire un « gpupdate /force » (pour forcer les GPO à remonter sur l'ordinateur)

```
C:\Users\Client02>gpupdate /force
Mise à jour de la stratégie...

La mise à jour de la stratégie d'ordinateur s'est terminée sans erreur.
La mise à jour de la stratégie utilisateur s'est terminée sans erreur.
```

5.se connecter au site en https (s'il n'y a aucune erreur alors la gpo fonctionne):



5)Créer une liste de révocation

Une liste de révocation de certificat sert à indiquer quels certificats numériques ne doivent plus être considérés comme valides, même si leur date d'expiration n'est pas encore atteinte.

Cela peut être utile par exemple si votre serveur GLPI a été hacké et que le hackeur a la clé privée de votre certificat.

5.1) Sur linux

1. Révoquer un certificat spécifique

```
./easyrsa revoke nom_du_certificat
```

2. Générer le fichier CRL

```
./easyrsa gen-crl
```

crée (ou met à jour) le fichier suivant :

```
pki/crl.pem
```

4.importer crl.pem sur serveur cible

```
scp -P <port ssh> pki/crl.pem <user@IP Machine cible>:/tmp/
```

5.déplacer au bon endroit

```
mv /tmp/crl.pem /etc/ssl/
```

6.Ajouter ceci dans default-ssl.conf

```
SSLCARevocationFile /etc/ssl/crl.pem

SSLCARevocationCheck chain
```

7.redémarrer le service

```
Systemctl restart apache2
```

5.2) Sur Windows

Exemple : https entre client01 et GLPI

<u>Sur SRV-PKI</u>

1.copier le crl.pem dans le share/ca-certificates

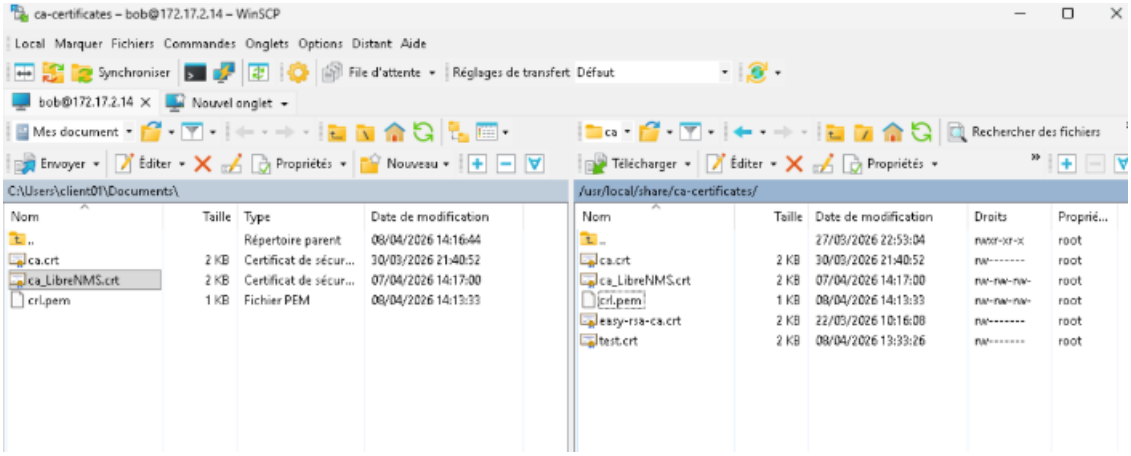
```
cp crl.pem /usr/local/share/ca-certificates
```

2.Lui donner les droits

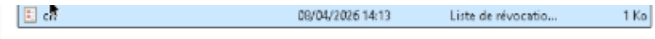
```
chmod 666 /usr/local/share/ca-certificates/crl.pem
```

<u>Sur Client01:</u>

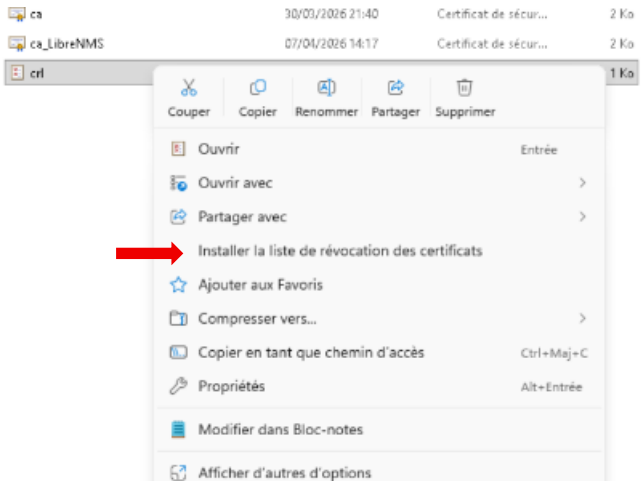
3.copier le fichier crl.pem sur Windows avec winscp



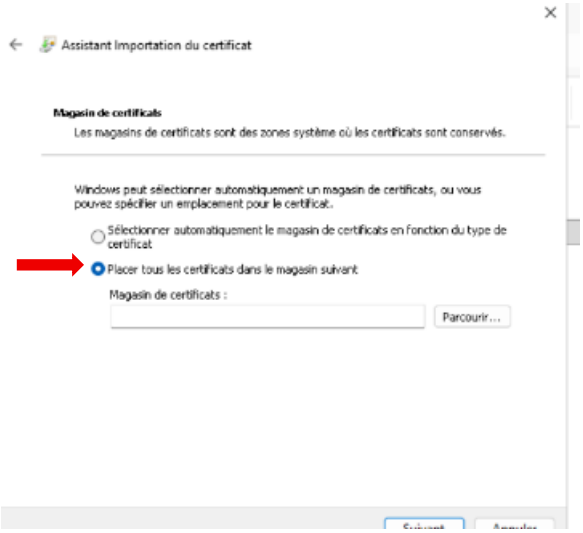
4.renommer le fichier crl.pem en crl.crl (Windows préfère l'extension. crl)



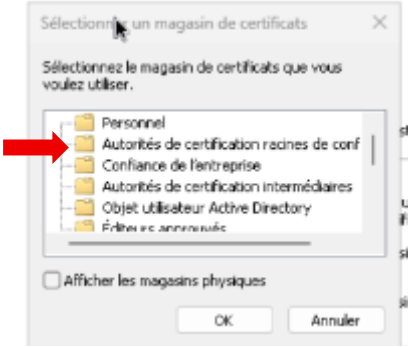
5.clic droit → « Installer la liste de révocation des certificats »



6.Sur la fenêtre qui s'ouvre « cocher placer tous les certificats dans le magasin suivant »



7.cliquer sur parcourir puis « autorité racine de confiance »



8.Suivant → Terminer